



SCHOOL OF COMPUTING, TECHNOLOGY & APPLIED SCIENCES

CIT3342-HACKING THEORY AND PRACTICE

**LAB N2: Password Hash Extraction and Exploitation Using Mimikatz
and Metasploit**

Due Date: 21st September, 2025

Names:

Student Number:

Programme:

Lecturer: Prof. Aaron Zimba

*These Labs are meant to be ethical training sessions designed to equip you as security professionals against potential security risks in various systems.
The skills and techniques taught, along with the tools used herein are intended for educational purposes only and should never be used against any other system.*

Introduction

Passwords are fundamental to the security of digital systems, providing a primary method of authentication for users. However, storing passwords in plaintext is inherently insecure, so operating systems use hashing algorithms to protect them. A hash is a cryptographic transformation of a password into a fixed-size string of characters, which is then stored instead of the actual password. Attackers often seek access to these hashed passwords from system files to perform offline attacks or further exploit them.

In Windows environments, hashed passwords are stored in specific files (e.g., SAM file for Windows), which are targeted by attackers. By exploiting vulnerabilities or gaining access to system privileges, attackers can extract these hashed passwords. Once they have the hashes, they can use various techniques to crack them or use them in attacks such as pass-the-hash.

This lab introduces Mimikatz, a powerful post-exploitation tool commonly used for extracting password hashes, credentials, and Kerberos tickets on Windows machines. Combined with Metasploit on Kali Linux, this lab demonstrates how an attacker can exploit a vulnerable system, escalate privileges, and extract password hashes from a target Windows XP machine.

Aim

To understand how attackers can exploit vulnerable systems to extract and utilize hashed passwords using tools like Mimikatz and Metasploit, and to develop awareness of the importance of securing password storage on operating systems.

Objectives

1. **Introduce students to password hashing and the concept of hashed password storage** in operating systems, specifically within Windows.

2. **Familiarize students with Metasploit and Mimikatz** as tools for exploitation and post-exploitation activities.
3. **Perform a simulated attack on a vulnerable Windows XP machine**, demonstrating how password hashes are stored and how attackers can extract them.
4. **Understand the importance of securing access to critical system files** where password hashes are stored, and the risks associated with unpatched systems.
5. **Demonstrate a pass-the-hash attack** using the extracted credentials to further emphasize the implications of compromised hashes.

Lab Setup

- **Attacker Machine:** Kali Linux with Metasploit and Mimikatz installed
- **Target Machine:** Windows XP with a vulnerable service that can be exploited for access

TASK1

Preparation and Setup:

- Set up the Windows XP target machine and ensure it is on the same network as the Kali Linux machine.
- Install the necessary tools on Kali Linux (Metasploit and Mimikatz).

Scanning and Vulnerability Assessment:

- Use Metasploit's scanning capabilities to discover the Windows XP target machine.
- Identify a vulnerable service on the Windows XP machine that can be exploited for initial access.

Exploitation:

- Use Metasploit to exploit the discovered vulnerability and gain a foothold on the Windows XP machine.
- Once inside, escalate privileges if necessary to gain SYSTEM-level access.

Post-Exploitation with Mimikatz:

- On the compromised Windows XP machine, deploy Mimikatz to extract password hashes.
- Locate the SAM file and extract NTLM hashes of user passwords.

Using the Extracted Hashes:

- Demonstrate how attackers can perform pass-the-hash attacks using the stolen hashes to authenticate to other machines or services on the network.
- (Optional) Attempt to crack the hashes offline using a tool like John the Ripper.

Cleanup:

- Ensure no traces of the attack are left on the Windows XP machine.
- Restore any settings altered during the attack simulation on both the target and the attacker machine.

TASK 2

- Use Metasploitable as the target machine. Exploit any vulnerabilities (apart from vsftpd) to gain root access.
- Locate the password file and copy it to your Kali machine.
- Use a password cracker to crack passwords for any of the users in the copied file.

Conclusion

- Summarize the attack process, from gaining access to escalating privileges and extracting password hashes.
- Discuss the significance of keeping systems updated and the importance of strong password policies to mitigate attacks like pass-the-hash..

Prepare a standard lab report in **PDF** format which should be submitted in Moodle (student portal) no later than the due date.

Your report should include screenshots taken on every necessary stage and every screenshot taken should be followed by an explanation. Number the steps your work properly and name your screenshots accordingly. Apart from giving a full analysis on each of the four tasks, you should suggest counter-measures in cases of weaknesses in the issue tackled and other implementations/applications of the concepts covered if there are “no” weaknesses found. Your last page should constitute the overall conclusion pertaining to the work done.

Please take note of the following:

- Your Lab report should start with a standard title page (A sample is provided as the end of this document). Then the Table of Contents should follow, then the Introduction (Chapter 1), then the main body where you solve Tasks 1 to 4 should be Chapter 2. After that, you should have your Conclusion (Chapter 3) (Your conclusion should be about your lab tasks, **NOT** generally about hacking), then end your document with the references used in IEEE format.
- Your lab report should include screenshots taken on every necessary stage and every screenshot taken should be followed by an explanation.
- Number the steps of your work properly and name your screenshots diagrams accordingly. Submit the work no later than the due date.

Sample Title Page



SCHOOL OF COMPUTING, TECHNOLOGY & APPLIED SCIENCES

CIT3342-HACKING THEORY AND PRACTICE

**LAB N1: Windows Back-door Exploitation, & Network Confidentiality
Hacking**

Due date:

Names:

Student Number:

Programme:

Lecturer: Prof. Aaron Zimba